

ZERO-DAY RESPONSE · STRATEGIC BRIEF

MiniPlasma

Mitigação Estratégica de Vulnerabilidade Kernel
em Driver Cloud Files do Windows

CVE-2020-17103 · Variante MiniPlasma · Divulgação Pública
18/Maio/2026

Documento técnico de orientação estratégica para times de Segurança e Endpoint de organizações expostas a esta vulnerabilidade, consolidando análise de impacto, justificativa técnica detalhada, plano de mitigação faseado por área de negócio e racional fundamentado para cada decisão recomendada. Cada seção é precedida do racional técnico que sustenta a recomendação e suportada por evidências verificáveis.



Rafael França

Cybersecurity Architect (CSA) · Customer Success Unit (CSU)
Microsoft Brasil

Escopo: ~dezenas de milhares de endpoints

Data: 04 de Junho de 2026

Versão: 2.0

1. Sumário Executivo

Racional Técnico - Antes de apresentar a recomendação, é fundamental que a liderança compreenda três fatos técnicos que sustentam a urgência: (1) o vetor de ataque opera em **nível de kernel**, abaixo da maioria das camadas de proteção corporativas; (2) o exploit foi **publicado e weaponizado** com PoC público funcional; (3) a Microsoft **ainda não disponibilizou** correção para a variante. Estes três fatos combinados elevam o caso para resposta emergencial.

⚠ Situação consolidada

Vulnerabilidade de elevação de privilégio (Local → SYSTEM) no driver `cldflt.sys` (Windows Cloud Files Mini Filter Driver) permite que qualquer usuário autenticado execute código com privilégios máximos do sistema operacional em estações Windows 10, Windows 11 e Windows Server 2022/2025 **totalmente atualizados**. PoC público publicado em 18/Mai/2026. Sem patch oficial até a data deste documento. Validação independente confirmou exploração bem-sucedida.

Dimensão	Status	Evidência
Vulnerabilidade tecnicamente confirmada	SIM	PoC público + validação interna uma instituição financeira de grande porte
Patch oficial Microsoft disponível	NÃO	MSRC em análise — sem ETA pública
Deteção por agentes EDR tradicionais	NÃO	Limitação arquitetural — ver Seção 3
Mitigação determinística disponível	SIM	Desabilitação controlada do driver vulnerável
Reversibilidade da mitigação	100%	Comando único + reinicialização
Impacto funcional ao usuário final	Mínimo	Apenas modo "Files On-Demand" do OneDrive
Volume estimado de endpoints expostos	dezenas de milhares	Estimativa de exposição organizacional

✅ Recomendação Microsoft — Customer Success Unit (CSU)

Implementar mitigação por desabilitação controlada do driver `cldflt.sys` em rollout segmentado por área de negócio ao longo de 30 dias, precedido por publicação de política OneDrive defensiva e ativação de telemetria proativa. Manter mitigação ativa até disponibilização e validação do patch oficial Microsoft.

2. Contexto Técnico da Ameaça

 **Racional Técnico** • Para tomar decisões corretas sobre uma vulnerabilidade kernel é necessário compreender **onde** ela vive na arquitetura do sistema operacional e **por que** esse posicionamento limita as opções de defesa. Sem este entendimento, escolhas de mitigação tornam-se intuitivas em vez de fundamentadas.

2.1 Linha do Tempo

Data	Evento
Dez/2020	Microsoft publica correção original para CVE-2020-17103 (Patch Tuesday)
Mai/2026	Pesquisador "Chaotic Eclipse" identifica bypass à correção de 2020
18/Mai/2026	Divulgação pública da variante MiniPlasma com PoC funcional
19/Mai/2026	Confirmação independente: exploit funciona em Windows 11 com updates de Maio/2026
22/Mai/2026	Múltiplas casas de threat intel publicam advisories
03/Jun/2026	Validações independentes confirmam exploração; agentes EDR atuais possuem limitação arquitetural conhecida
04/Jun/2026	Este documento — recomendação de mitigação estratégica

 **Evidência verificada** • Fontes públicas consultadas (Mai-Jun/2026): The Hacker News · ThreatLocker Research Blog · Cyber Security News · NormCyber Threat Bulletin · Picus Security Research · Eastern Herald · Windows Forum community analysis · Microsoft Security Response Center (MSRC) — caso em triagem ativa.

2.2 Família de Vulnerabilidades — Não é caso isolado

 **Racional Técnico** • MiniPlasma não é um achado isolado. O mesmo pesquisador identificou previamente duas outras vulnerabilidades de mesma classe (**YellowKey** e **GreenPlasma**) na superfície de drivers mini-filter do Windows. Isto indica que estamos diante de uma **classe de bugs** em exploração ativa por pesquisa pública — recomenda-se postura defensiva ampliada nesta superfície de ataque, não apenas correção pontual.

2.3 Mecânica da Exploração

 **Racional Técnico** • Entender o vetor permite avaliar com precisão as opções de mitigação. O exploit não usa nenhum truque obscuro — usa **uma chamada legítima de sistema** para um driver legítimo. É exatamente isso que o torna invisível para camadas tradicionais de detecção.

Etapa	Ação técnica
1. Pré-requisito	Atacante possui execução local em integridade média (usuário comum)
2. Acesso ao driver	Abre handle para <code>\\.\CldFlt</code> — operação documentada e legítima
3. Envio do payload	Chama <code>DeviceIoControl</code> / <code>FltSendMessage</code> com IOCTL <code>HsmOsBlockPlaceholder</code> contendo estrutura forjada
4. Confusão no kernel	Driver processa estrutura sem validação adequada, causando type confusion / arbitrary write em memória kernel
5. Escalação	Atacante reescreve token de segurança do processo para SYSTEM
6. Persistência opcional	Com SYSTEM, instala backdoor, desabilita defesas, exfiltra credenciais

3. Por Que Soluções EDR Tradicionais Não Detectam (Limitação Arquitetural)

🧠 **Racional Técnico** • Esta seção é deliberadamente focada em arquitetura — não em produtos específicos. A limitação aqui descrita aplica-se a **qualquer agente de proteção de endpoint baseado em mini-filter**, independentemente do fabricante. O objetivo é explicar à liderança técnica do cliente por que a falha de detecção observada no teste interno **não é um defeito do produto contratado**, mas uma limitação inerente ao modelo arquitetural utilizado por toda a indústria EDR atual. Esta clareza é fundamental para evitar conclusões equivocadas e direcionar a discussão para a camada correta da solução.

3.1 Onde Vivem os Agentes EDR — A Stack Mini-Filter

O Windows expõe uma arquitetura de drivers chamada **Filter Manager** (`fltmg.sys`) onde múltiplos drivers do tipo *mini-filter* são registrados em camadas (*altitudes*). Cada driver intercepta operações de I/O em arquivos e pode inspecionar, modificar ou bloquear essas operações. **Agentes EDR modernos operam exatamente nesta camada** — é o mecanismo oficial e suportado pela Microsoft para inspeção comportamental de arquivos em tempo real.

Altitude	Tipo de driver	Função típica
420000+	Mini-filters de FSFilter Activity Monitor	Monitoramento e auditoria
320000-329999	Mini-filters de FSFilter Anti-Virus	Inspeção AV / EDR comportamental
280000-289999	Mini-filters HSM (Hierarchical Storage Mgmt)	cldflt.sys vive aqui — Cloud Files
180000-189999	Mini-filters de Encryption	BitLocker, EFS

3.2 A Razão Técnica da Não-Detecção

🎯 Ponto crítico

O exploit MiniPlasma **não cria nenhum arquivo, processo ou conexão de rede suspeitos**. Ele simplesmente envia uma mensagem IOCTL *tecnicamente válida* para um driver *oficialmente carregado* da Microsoft. Para o agente EDR, esta operação é indistinguível de uma chamada legítima do cliente OneDrive. A confusão ocorre **dentro do código kernel do driver vulnerável**, em uma região de memória que o EDR *não tem visibilidade nem permissão* para inspecionar.

3.3 Quatro Razões Arquiteturais

① Operação em mesmo plano

EDR e driver vulnerável operam ambos em kernel mode. Um driver não pode inspecionar o estado interno de outro driver — isto violaria o modelo de isolamento do Windows.

② Chamada de API legítima

O exploit usa `DeviceIoControl` — uma das APIs mais comuns do Windows, executada milhões de vezes por dia em cada endpoint. Bloquear ou alertar geraria falso positivo proibitivo.

③ Sem assinatura comportamental

Não há criação de processo filho, escrita em disco, conexão de rede ou acesso a credenciais *antes* da escalação. Todos os indicadores comportamentais que EDR usa para detecção **aparecem apenas DEPOIS** de SYSTEM já ter sido obtido.

④ Bypass de hooks AMSI/ETW

Uma vez com SYSTEM, o atacante pode desabilitar a telemetria do próprio EDR (ETW providers, callbacks de PsSetCreate). A janela de detecção é de milissegundos — insuficiente para resposta automatizada.

3.4 O Que Isto Significa na Prática

💡 Conclusão técnica honesta

Nenhum agente EDR *do mercado atual* — incluindo soluções líderes reconhecidas em Gartner Magic Quadrant, MITRE Engenuity ATT&CK Evaluations e relatórios independentes — possui capacidade arquitetural para detectar exploração de vulnerabilidades kernel desta classe **antes** da escalação ocorrer. Esta é uma limitação da geração atual de tecnologia EDR, não de um fornecedor específico. A defesa efetiva requer **eliminar a superfície de ataque** (remover o driver vulnerável do kernel) ou **aplicar o patch do fabricante do SO** (Microsoft) quando disponível.

3.5 O Que Camadas Adjacentes Podem (e Não Podem) Fazer

Camada de defesa	Capacidade frente ao MiniPlasma	Limite
EDR comportamental	Não detecta a exploração	Opera no mesmo plano kernel
EDR pós-exploração	Detecta indicadores após SYSTEM obtido	Tarde demais — atacante já tem o que precisa
Application Control (allow-listing)	Reduz superfície impedindo execução do payload inicial	Não bloqueia exploração se atacante já tem execução
Hypervisor-Protected Code Integrity (HVCI)	Mitigação parcial contra escrita arbitrária	Requer hardware compatível e habilitação prévia
Credential Guard / LSA Protection	Protege credenciais pós-SYSTEM	Reduz dano mas não previne a escalação
Desabilitar o driver (esta recomendação)	Elimina o vetor de forma determinística	Requer reboot; trade-off funcional do OneDrive Files On-Demand

4. Plano de Ação — Tarefas Sequenciais Recomendadas

 **Racional Técnico** · Cada tarefa abaixo é apresentada com seu racional técnico, critério de sucesso e responsável sugerido. Esta sequência foi desenhada para **maximizar segurança** (eliminar o vetor) e **minimizar impacto operacional** (evitar storm de download, falsos positivos, indisponibilidade de OneDrive). A ordem importa — executar fora de sequência aumenta risco operacional.

1

Aprovação Emergencial em Change Advisory Board

Racional: mudança em driver de kernel exige governança formal. Aprovação prévia evita questionamentos posteriores e habilita rollback rápido se necessário.

Critério de sucesso: CAB extraordinário aprovado com janela de 30 dias para execução faseada.

Responsável: Gestão de Mudanças · **Prazo:** 24h · **Bloqueia:** todas as próximas tarefas

2

Validação Definitiva em Ambiente Controlado

Racional: antes de aplicar em 51 mil endpoints, validar comportamento em VM isolada elimina risco de surpresas. Confirma que mitigação realmente bloqueia o PoC interno.

Critério de sucesso: PoC interno executa com sucesso ANTES da mitigação, e falha com `STATUS_OBJECT_NAME_NOT_FOUND` DEPOIS da mitigação + reboot.

Responsável: Red Team / Endpoint Engineering · **Prazo:** 48h

3

Publicar Política OneDrive Defensiva (GPO/Intune)

Racional: com a política ativa, o cliente OneDrive entra em "graceful degradation" quando o driver é removido — arquivos cloud-only ficam indisponíveis para abertura em vez de tentar re-hidratação massiva, eliminando risco de storm de banda.

Configuração: `FilesOnDemandEnabled=1`, `DehydrateSyncedTeamSitesFiles=1`, `DownloadBandwidthLimited=5120` (5 MB/s).

Responsável: Endpoint Management · **Prazo:** 72h antes do primeiro anel

4

Ativar Telemetria Proativa de Storm de Download

Racional: detecção em tempo real de download anômalo permite pausa automática do próximo anel antes que afete WAN regional. Sem este controle, descobre-se o problema apenas pelo Service Desk — tarde demais.

Critério de sucesso: alerta KQL ativo no SIEM corporativo com canal Teams notificando SOC, threshold de 500 MB/5min por endpoint.

Responsável: SOC / Detection Engineering · **Prazo:** 72h antes do primeiro anel

5

Pré-verificação de Elegibilidade por Endpoint

Racional: identificar antecipadamente endpoints com volume crítico no OneDrive ou pouco espaço em disco. Tratamento individualizado para minoria evita incidentes em massa.

Critério de sucesso: relatório CSV com classificação **SafeToMitigate** para 100% dos endpoints do anel atual, lista de exceção encaminhada para tratamento manual.

Responsável: Endpoint Engineering · **Prazo:** 24h antes de cada anel

6

Comunicação Direcionada aos Gestores de Cada Anel

Racional: gestores informados conseguem absorver eventuais dúvidas de usuários antes do Service Desk. Mensagem técnica adaptada para audiência não-técnica reduz ansiedade e ruído operacional.

Critério de sucesso: e-mail formal enviado aos gestores 24h antes do início do anel correspondente, com FAQ pronto.

Responsável: Comunicação Interna / Endpoint · **Prazo:** 24h antes de cada anel

7

Execução do Rollout Segmentado em 6 Anéis

Racional: segmentação por criticidade + geografia + janela horária distribui carga de rede, permite aprendizado entre fases e protege agências com link reduzido. Rollout simultâneo em 51 mil endpoints é tecnicamente arriscado mesmo com download orgânico.

Anéis: Piloto (~100) → A1 Admin/TI (~3k) → A2 Tesouraria (~5k) → A3 Back-office (~15k) → A4 Agências Metro (~12k) → A5 Agências Interior (~20k).

Responsável: Endpoint Engineering + NOC + SOC · **Prazo:** 30 dias corridos

8

Abertura de Caso Microsoft Premier Support em Paralelo

Racional: caso formal acelera a comunicação MSRC sobre ETA do patch, habilita acesso a pre-release patches quando disponíveis e garante suporte direto da Microsoft durante toda a janela de exposição.

Critério de sucesso: número de caso Premier atribuído com severidade A, Technical Account Manager designado para acompanhamento diário.

Responsável: Microsoft CSA + uma instituição financeira de grande porte Premier Contact · **Prazo:** 24h

9

Reversão Controlada Após Disponibilização do Patch Oficial

Racional: mitigação é solução temporária. O patch da Microsoft é a correção definitiva e restaura todas as funcionalidades. Reversão deve ser tão controlada quanto a aplicação.

Critério de sucesso: KB validado em ambiente de teste, aplicado nos endpoints já mitigados, mitigação revertida, PoC interno re-executado e confirmado bloqueio pelo patch.

Responsável: Endpoint + Red Team · **Prazo:** 7 dias após release do KB Microsoft

5. Mitigação Técnica Detalhada

💡 **Racional Técnico** • A solução é uma única alteração de configuração de serviço de driver. A simplicidade aparente esconde a robustez: ao alterar o tipo de inicialização do driver para *disabled*, o Filter Manager do Windows recusa carregá-lo no boot. Sem o driver em memória kernel, o IOCTL vulnerável torna-se literalmente inalcançável — não há superfície de ataque para explorar.

5.1 Comando de Mitigação

```
sc.exe config cldfilt start= disabled
```

Reboot obrigatório. Sem reinicialização, o driver permanece em memória e ainda explorável.

5.2 Comando de Rollback

```
sc.exe config cldfilt start= demand
```

Reboot obrigatório. Restaura o estado original. Nenhum dado é alterado ou perdido.

5.3 Validação Pós-Aplicação

```
# Confirma configuração persistente
sc.exe qc cldfilt | findstr START_TYPE
# Esperado: START_TYPE : 4    DISABLED

# Confirma que o driver NÃO está em memória
fltmc filters | findstr cldfilt
# Esperado: (vazio)
```

5.4 Script de Deploy Production-Ready

```
# Deploy-MitigateMiniPlasma.ps1
# Compatível com Intune Win32 / SCCM Package / GPO Startup Script

[CmdletBinding()]
param([switch]$Rollback)

$LogPath = "$env:ProgramData\uma instituição financeira de grande porte\Hardening\Mir
New-Item -ItemType Directory -Force -Path (Split-Path $LogPath) | Out-Null

function Write-Log($msg) {
    "$((Get-Date -Format o) [$env:COMPUTERNAME] $msg" |
        Tee-Object -FilePath $LogPath -Append
}

try {
    # Guard crítico: abortar em servidores Azure File Sync
    if (Get-Service -Name FileSyncSvc -ErrorAction SilentlyContinue) {
        Write-Log "ABORT: Azure File Sync detected - host excluded from scope"
        exit 2
    }

    $current = (Get-ItemProperty `
        'HKLM:\SYSTEM\CurrentControlSet\Services\cldflt').Start
    Write-Log "PRE: cldflt Start=$current"

    if ($Rollback) {
        sc.exe config cldflt start= demand | Out-Null
        Write-Log "ROLLBACK: Start=3 (demand) - reboot required"
    } else {
        sc.exe config cldflt start= disabled | Out-Null
        Write-Log "MITIGATED: Start=4 (disabled) - reboot required"
    }

    $new = (Get-ItemProperty `
        'HKLM:\SYSTEM\CurrentControlSet\Services\cldflt').Start
    Write-Log "POST: Start=$new"
    exit 0
}
catch {
    Write-Log "ERROR: $($_.Exception.Message)"
    exit 1
}
```

6. Rollout Segmentado por Área de Negócio

 **Racional Técnico** • Rollout massivo simultâneo apresenta riscos reais mesmo com download orgânico: saturação de WAN em agências regionais, storm de chamados, falsos positivos de DLP, inviabilidade de rollback rápido. Segmentação por anel de criticidade distribui carga, permite aprendizado e mantém capacidade de pausa imediata.

Anel	Área de Negócio	Volume	Janela	Racional
Piloto	TI / SOC / Segurança	~100	D+0 → D+2	Validação técnica com equipe capacitada
A1	Administrativo / DevOps / TI Corporativa	Grupo pequeno	D+2 → D+5	Maior valor para atacante (credenciais, código)
A2	Tesouraria / Mesa / Áreas Reguladas	Grupo pequeno-médio	D+5 → D+8	Compliance + risco financeiro elevado
A3	Back-office Sede + Corporativo	Grupo médio-grande	D+8 → D+14	Volume médio em rede robusta da sede
A4	Agências Região Metropolitana	Grupo médio-grande	D+14 → D+21	Links de qualidade, suporte presencial próximo
A5	Agências Interior	Grupo grande	D+21 → D+30	Maior risco de WAN — última fase, ondas regionais

6.1 Critério "Stop the Line"

Métrica	Limite	Ação
Chamados Service Desk relacionados	> 2% do anel	Pausa + análise causa-raiz
Saturação WAN em qualquer site	> 80% por 30min	Reduzir concorrência pela metade
Falhas de boot pós-mitigação	> 0,1% do anel	Abortar imediato + investigação
Disponibilização do patch oficial Microsoft	—	Pausar + planejar reversão

7. Impacto ao Usuário Final

 **Racional Técnico** • Para o usuário final, a alteração técnica é praticamente imperceptível. Toda funcionalidade corporativa permanece operacional. A única diferença observável é no comportamento do OneDrive: arquivos passam a ser baixados localmente em vez de existirem como placeholders na nuvem.

 **Continua funcionando 100%**

 **Única alteração**

Login OneDrive corporativo · Sincronização da pasta OneDrive · Bibliotecas SharePoint · Arquivos Teams · Upload/download · Coautoria · Versionamento · Compartilhamento · Known Folder Move · Office · Outlook · VPN · Impressão · Mapeamentos de rede

OneDrive deixa de operar em modo "Arquivos Sob Demanda" () e passa a operar em modo clássico: arquivos baixados integralmente. Impacto único é consumo adicional de espaço em disco proporcional ao volume do usuário — imperceptível para perfil típico bancário.

8. Detecção Compensatória Durante Janela de Exposição

Racional Técnico - Enquanto a mitigação não estiver aplicada em 100% dos endpoints, e mesmo após o rollout completo, recomenda-se telemetria compensatória para identificar tentativas de exploração ou indicadores pós-comprometimento. Detecção tardia ainda é valiosa para resposta a incidente.

8.1 Consulta KQL para SIEM Corporativo

```
// Detecta carregamento anômalo de cldflt.sys fora do contexto OneDrive
DeviceImageLoadEvents
| where FileName =~ "cldflt.sys"
| where InitiatingProcessFileName !in~ (
    "OneDrive.exe", "FileCoAuth.exe", "svchost.exe", "System")
| project Timestamp, DeviceName, InitiatingProcessFileName,
    InitiatingProcessCommandLine, InitiatingProcessAccountName
| order by Timestamp desc
```

8.2 Indicadores Pós-Comprometimento

- Processos rodando como SYSTEM cujo pai não é SYSTEM
- Alterações em **HKLM\SYSTEM\CurrentControlSet\Services** por processos não-trusted
- Desabilitação súbita de ETW providers de segurança
- Acesso anômalo a **Lsass.exe** após elevação

9. Defesa em Profundidade Recomendada

Racional Técnico - A mitigação é necessária mas não suficiente. Recomenda-se reforçar camadas adjacentes para reduzir superfície de ataque geral e limitar dano caso novas variantes da mesma classe sejam descobertas.

Camada	Controle	Prioridade
Kernel	Mitigação cldflt.sys (este documento)	Imediato
Application Control	Allow-listing + deny rules para drivers vulneráveis conhecidos	Curto prazo
ASR	Attack Surface Reduction rules em modo Block	Reforçar
Credential	LSA Protection (RunAsPPL) + Credential Guard	Validar
HVCI	Hypervisor-Protected Code Integrity habilitado onde compatível	Médio prazo
PowerShell	Constrained Language Mode	Onde aplicável
Detecção	KQL + Sysmon EID 6/11 conforme Seção 8	Implantar

10. Resumo de Decisões Solicitadas ao Cliente

1. **Aprovação do CAB emergencial** para execução do plano nas próximas 24h
2. **Designação de líder de execução** com autoridade para "stop the line"
3. **Confirmação de abertura de caso Microsoft Premier** via canal oficial
4. **Validação de exclusões obrigatórias** (servidores Azure File Sync) antes do rollout
5. **Aprovação do cronograma de 30 dias** com checkpoints entre anéis

11. Referências Técnicas

 **Evidência verificada** · Microsoft Security Response Center · Microsoft Filter Manager documentation (`fltmgr.sys` , `FltSendMessage` , IOCTL semantics) · Microsoft Docs — Cloud Files API e `cldfilt.sys` internals · The Hacker News (18/Mai/2026) — divulgação inicial MiniPlasma · ThreatLocker Research Blog (19/Mai/2026) — análise técnica e confirmação em Windows 11 Mai/2026 patched · NormCyber Threat Bulletin (22/Mai/2026) · Picus Security Research — "The Return of a Ghost: Unpacking MiniPlasma" · Eastern Herald · Cyber Security News · MITRE ATT&CK T1068 (Exploitation for Privilege Escalation).

MiniPlasma — Mitigação Estratégica para uma instituição financeira de grande porte · v2.0

Autor: **Rafael França** · Cybersecurity Architect (CSA) · Customer Success Unit (CSU) · Microsoft Brasil

Data: 04 de Junho de 2026 · Classificação: Público — Distribuição Permitida

Este documento representa recomendação técnica do time Microsoft Customer Success Unit (CSU) e não substitui advisory oficial MSRC quando disponível.